

COMPANION DIGITAL PACKAGE

Two Full Mock Exams

75 questions each · 90-minute format · Full answer keys

Mastering Identity Security for CIDPro™
Abbas Kudrati | 2026 Edition

75
Questions per Exam

2
Full Exams

90
Minutes per Exam

5
Objectives Covered

These two mock exams simulate the format and difficulty of the actual CIDPro™ certification examination. Each exam contains 75 multiple-choice questions across all five CIDPro™ exam objectives. The real exam allows 90 minutes and requires a 70% passing score (53 correct answers).

- Set a 90-minute timer before you begin. Stop when the timer ends.
- Do not refer to the book, your notes, or this answer key until you have completed the exam.
- Answer every question — there is no penalty for guessing.
- Record your answers on paper or in a separate document.
- Score yourself using the answer key at the end of each exam section.

Score	Result	What to do
68–75 (91–100%)	Outstanding	You are well prepared. Review any missed questions briefly.
60–67 (80–89%)	Comfortable pass	Review the chapters for any questions you missed.
53–59 (70–79%)	Borderline pass	Focused review of weak objective areas before the exam.
45–52 (60–69%)	Near miss	Re-read the relevant chapters and re-sit this mock exam.
Below 45 (<60%)	More preparation needed	Work through the book systematically before attempting again.

Key tip: Watch for qualifier words — *best, most appropriate, first, primary*. These words change the meaning of a question significantly. Read the full scenario before looking at the options. Eliminate obviously wrong answers first.

Mock Exam 1

75 questions | 90 minutes | Pass: 53+ correct (70%)

Objective 2 — Identifiers, Identity Lifecycle & Proofing

Question 1 [Ch 8 — Obj 2.3]

An applicant creates a social media account by entering only a username and email address, with no additional verification. What Identity Assurance Level does this represent?

- A. IAL1
- B. IAL2
- C. IAL3
- D. AAL1

Question 2 [Ch 8 — Obj 2.3]

A government employee renewing their defence clearance must attend an appointment at a secure facility, present original documents to an authorised representative, and have a new biometric captured. What IAL level does this represent?

- A. IAL1
- B. IAL2
- C. IAL3
- D. AAL3

Question 3 [Ch 8 — Obj 2.3]

A subscriber who has been identity proofed at IAL2 attempts to log into a government benefits portal. In the NIST 800-63 model, what term describes the subscriber at the moment of authentication?

- A. Applicant
- B. Verifier
- C. Claimant
- D. Relying Party

Question 4 [Ch 8 — Obj 2.3]

An organisation is designing a proofing workflow for a new healthcare portal that will provide access to highly sensitive patient records. Which combination of proofing requirements is most appropriate?

- A. IAL1 with email confirmation only
- B. IAL2 with document upload and optional biometric
- C. IAL3 with in-person proofing and mandatory biometric
- D. FAL3 with encrypted federation assertion

Question 5 [Ch 8 — Obj 2.3]

What is the key difference between IAL2 and IAL3 in the NIST 800-63 framework?

- A. IAL3 requires biometric binding while IAL2 does not permit biometrics
- B. IAL3 requires in-person proofing; IAL2 permits either remote or in-person
- C. IAL2 applies only to government use cases; IAL3 applies to commercial contexts
- D. IAL3 is applied to authentication strength; IAL2 is applied to proofing strength

Objective 3 — Core Concepts of Security for Identity**Question 6** [Ch 9 — Obj 3.1]

A user logs into their corporate portal by entering a password and then approving a push notification on their registered smartphone. Which authentication factor categories are being used?

- A. Something you know and something you are
- B. Something you have and something you are
- C. Something you know and something you have
- D. Two instances of something you know

Question 7 [Ch 9 — Obj 3.1]

An attacker calls a mobile carrier, pretends to be the account holder, and convinces the carrier to transfer the victim's phone number to a new SIM. The attacker then intercepts SMS authentication codes. What type of attack is this?

- A. Credential stuffing
- B. SIM swapping
- C. MFA fatigue
- D. Presentation attack

Question 8 [Ch 9 — Obj 3.1]

What is the key distinction between OIDC and OAuth 2.0?

- A. OAuth 2.0 is for authentication; OIDC is for authorisation
- B. OIDC is for authentication; OAuth 2.0 is for authorisation
- C. Both protocols serve the same purpose but use different token formats
- D. OIDC uses XML tokens; OAuth 2.0 uses JSON tokens

Question 9 [Ch 9 — Obj 3.1]

Under NIST SP 800-63B, what property must an authentication method have to qualify as AAL3?

- A. It must use two separate authentication factors
- B. It must use a hardware-bound cryptographic key that provides verifier impersonation resistance
- C. It must require in-person identity proofing at enrollment
- D. It must be integrated with a federated identity provider

Question 10 [Ch 9 — Obj 3.1]

An enterprise deploys SAML to connect their corporate IdP to thirty SaaS applications. What format does the authentication assertion take in a SAML flow?

- A. JSON Web Token (JWT)
- B. XML-based assertion
- C. Bearer token with PKCE
- D. FIDO2 attestation statement

Question 11 [Ch 10 — Obj 3.2]

An employee in the Finance department is transferred to the Legal department. Their Finance Analyst role is not revoked, and a Legal Associate role is added. Six months later, they still have access to financial reporting systems they no longer need. What access control failure does this illustrate?

- A. Role explosion
- B. Role creep
- C. Separation of Duties violation
- D. Discretionary access control failure

Question 12 [Ch 10 — Obj 3.2]

What is the primary purpose of the principle of least privilege?

- A. To ensure users can access all resources needed for their role without additional approvals
- B. To minimise the permissions granted to each identity so that a compromise causes the least possible harm
- C. To prevent any single user from holding more than one role simultaneously
- D. To require that all access requests are approved by a manager before provisioning

Question 13 [Ch 10 — Obj 3.2]

An organisation's IGA tool flags that a single user holds both "create purchase order" and "approve purchase order" roles. What control principle is being violated?

- A. Least privilege
- B. Just-in-Time access
- C. Separation of Duties
- D. Role-Based Access Control

Question 14 [Ch 10 — Obj 3.2]

In OAuth 2.0, what is a scope?

- A. The time window during which an access token is valid
- B. A string designating the specific subset of a protected resource that a client application is authorised to access
- C. The cryptographic algorithm used to sign the access token
- D. The identity of the resource owner who granted access

Question 15 [Ch 10 — Obj 3.2]

In the RBAC model, how are permissions typically assigned to users?

- A. Directly, based on individual access requests approved by a manager
- B. Through role membership — users are assigned to roles that carry the appropriate permissions
- C. Through attribute evaluation at the time of each access request
- D. Through ownership of specific resources

Question 16 [Ch 11 — Obj 3.3]

A former contractor's account remains active six months after their engagement ended because no termination email was sent to IT. What type of access management failure is this?

- A. Role explosion
- B. Orphaned account
- C. Session timeout failure
- D. Separation of Duties violation

Question 17 [Ch 11 — Obj 3.3]

A partner organisation's employees need to access a supplier portal using their own corporate credentials, without creating new accounts in the supplier's identity system. What access management architecture supports this?

- A. Provisioning via SCIM
- B. Identity federation
- C. Session management
- D. Self-service access request

Question 18 [Ch 11 — Obj 3.3]

What is the primary security risk of failing to implement session timeout?

- A. Users can bypass MFA requirements
- B. Idle authenticated sessions remain active and can be hijacked from unattended devices
- C. Sessions cannot be revoked when accounts are terminated
- D. Token expiry times cannot be configured

Question 19 [Ch 11 — Obj 3.3]

Which SIEM platform is specifically named in the Microsoft Azure ecosystem for identity-focused monitoring and threat detection?

- A. Splunk
- B. AWS CloudTrail
- C. IBM QRadar
- D. Microsoft Sentinel

Question 20 [Ch 11 — Obj 3.3]

An organisation's access logs show that a user authenticated from Sydney at 8 AM and then successfully authenticated from London at 8:45 AM. What type of anomaly does this represent?

- A. Session timeout violation
- B. Role creep
- C. Impossible travel — potential account compromise
- D. SoD violation

Question 21 [Ch 12 — Obj 3.4]

An identity platform stores user passwords in its database. Which approach best protects stored passwords against exposure in a database breach?

- A. AES-256 encryption of each password using a shared database key
- B. SHA-256 hash of each password stored without modification
- C. bcrypt hash with a unique salt per user and a configurable work factor
- D. Base64 encoding of each password before storage

Question 22 [Ch 12 — Obj 3.4]

An IdP signs a SAML assertion using its private key. A Service Provider wants to verify the assertion. Which key does the SP use?

- A. The SP's own private key
- B. The SP's own public key
- C. The IdP's private key
- D. The IdP's public key

Question 23 [Ch 12 — Obj 3.4]

A user logs into a web application over HTTPS. What cryptographic protocol protects their credentials in transit?

- A. AES-256 symmetric encryption applied directly to the credentials
- B. Transport Layer Security (TLS)
- C. bcrypt password hashing
- D. JWT token signing

Question 24 [Ch 12 — Obj 3.4]

What is the purpose of adding a salt to a password before hashing?

- A. To make the hash computation faster
- B. To encrypt the hash so it cannot be read from the database
- C. To ensure identical passwords produce different hashes, defeating rainbow table lookups
- D. To make the hash output longer and harder to guess

Question 25 [Ch 12 — Obj 3.4]

In a JWT, which segment contains the claims about the authenticated user?

- A. The header
- B. The payload
- C. The signature
- D. The certificate

Question 26 [Ch 13 — Obj 3.5]

An attacker obtains a user's username and password through a phishing campaign, then attempts to log in. The system challenges them for an OTP from an authenticator app. The attacker is operating an adversary-in-the-middle proxy and relays the OTP in real time. The login succeeds. Which authentication control would have prevented this attack?

- A. SMS-based one-time password
- B. TOTP authenticator app with 30-second codes
- C. FIDO2 hardware security key
- D. Push notification with biometric unlock

Question 27 [Ch 13 — Obj 3.5]

An attacker sends an employee 47 push notification authentication requests in ten minutes. The employee approves one to make them stop. What attack technique is this, and what is the primary mitigation?

- A. Phishing; deploy FIDO2 hardware keys
- B. MFA fatigue / prompt bombing; enable number matching on push notifications
- C. Credential stuffing; deploy breach credential monitoring
- D. Session hijacking; enforce short session lifetimes

Question 28 [Ch 13 — Obj 3.5]

An attacker in a Windows Active Directory environment extracts the NTLM hash of a domain user's password from system memory. They then use this hash to authenticate to other servers in the environment without knowing the actual password. What attack technique is this?

- A. Golden Ticket
- B. Pass-the-Ticket
- C. Pass-the-Hash
- D. Token relay

Question 29 [Ch 13 — Obj 3.5]

In the Snowflake-related breaches of May 2024, what was the primary security control whose absence enabled the breaches?

- A. Encryption of data at rest in Snowflake tenants
- B. Network-level firewall restrictions on Snowflake access
- C. Multi-factor authentication enforcement on Snowflake tenant administrator accounts
- D. Certificate pinning on Snowflake API connections

Question 30 [Ch 13 — Obj 3.5]

Which of the following is the most effective control against credential stuffing attacks?

- A. Account lockout after five failed attempts
- B. Requiring passwords to be at least 12 characters
- C. Multi-factor authentication enforcement
- D. CAPTCHA on the login page

Question 31 [Ch 14 — Obj 3.6]

During a STRIDE threat analysis of an OAuth authorisation server, the team identifies that the server does not validate the `aud` (audience) claim in tokens before they are accepted by consuming services. Which STRIDE category does this threat primarily fall under?

- A. Spoofing
- B. Tampering
- C. Information Disclosure
- D. Elevation of Privilege

Question 32 [Ch 14 — Obj 3.6]

An attacker creates a phishing page that looks identical to the corporate SSO login page, hosted at a domain one character different from the real domain. Which STRIDE category classifies this threat?

- A. Tampering
- B. Information Disclosure
- C. Spoofing
- D. Elevation of Privilege

Question 33 [Ch 14 — Obj 3.6]

The access logs for a privileged identity management system show that a highly sensitive administrative action was performed, but the log entry does not include the identity of the approver or the identity of the individual who performed the action — only a service account name. Which STRIDE category does this represent a failure of?

- A. Tampering
- B. Spoofing
- C. Repudiation
- D. Information Disclosure

Question 34 [Ch 14 — Obj 3.6]

A security team is applying DREAD scoring to two threats. Threat A scores $9/10/9/10/8 = 46$. Threat B scores $5/3/4/6/2 = 20$. Which threat should be prioritised, and why?

- A. Threat B, because lower-scoring threats are easier to fix
- B. Threat A, because its higher DREAD score indicates greater severity, reproducibility, and impact
- C. Both equally — DREAD scores are absolute measures, not comparative
- D. Neither — DREAD requires security expert validation before it can guide prioritisation

Question 35 [Ch 14 — Obj 3.6]

What is the primary security benefit of shift-left threat modelling in a DevSecOps pipeline?

- A. It enables penetration testing to be eliminated from the release cycle
- B. It moves threat identification to the design phase, where remediations are least expensive to implement
- C. It automates the detection of STRIDE threats using CI/CD pipeline tools
- D. It ensures that threat models are approved by regulatory bodies before deployment

Objective 4 — Rules and Standards That Relate to Identity

Question 36 [Ch 15 — Obj 4.1]

A Singapore-based organisation serves customers in Germany, Australia, and the United States. Under which framework do they have a 72-hour breach notification obligation?

- A. Singapore PDPA
- B. Australian Privacy Act (NDB scheme)
- C. GDPR
- D. CCPA

Question 37 [Ch 15 — Obj 4.1]

Under NIST SP 800-63, which IAL level requires in-person identity proofing with physical inspection of documentary evidence?

- A. IAL1
- B. IAL2
- C. IAL3
- D. IAL4

Question 38 [Ch 15 — Obj 4.1]

Which standards body governs the SAML 2.0 specification?

- A. IETF
- B. OpenID Foundation
- C. FIDO Alliance
- D. OASIS

Question 39 [Ch 15 — Obj 4.1]

An organisation identifies a potential data breach on Monday at 9am. They complete their internal assessment by Tuesday at 6pm and determine the breach is notifiable under GDPR. They notify the supervisory authority on Thursday at 10am. Have they met the GDPR breach notification requirement?

- A. Yes — notification occurred within one week, which is acceptable
- B. Yes — notification occurred within 72 hours of completing their assessment
- C. No — the 72-hour clock starts when the organisation first becomes aware of the breach, not when the assessment is complete
- D. No — GDPR requires notification within 24 hours of becoming aware

Question 40 [Ch 15 — Obj 4.1]

What is the primary difference between a data controller and a data processor under GDPR?

- A. The controller stores data; the processor uses it
- B. The controller determines the purposes and means of processing; the processor processes data on behalf of the controller
- C. The controller is always a private company; the processor is always a government body
- D. The controller requires consent; the processor does not

Question 41 [Ch 16 — Obj 4.2]

A cloud-native company wants real-time visibility into whether MFA is enabled for all administrator accounts, with automatic alerts if any admin account loses MFA. Which compliance approach does this represent?

- A. Risk-based compliance
- B. Control-based compliance
- C. Audit and certification
- D. Continuous compliance

Question 42 [Ch 16 — Obj 4.2]

A SaaS vendor provides a SOC 2 Type II report to enterprise customers covering a twelve-month observation period. What does this report specifically attest?

- A. That the vendor's controls were designed correctly at a single point in time
- B. That the vendor's controls both existed and operated effectively throughout the twelve-month period
- C. That the vendor has no security vulnerabilities in its identity systems
- D. That the vendor meets all GDPR and HIPAA requirements

Question 43 [Ch 16 — Obj 4.2]

Which NIST 800-53 control family addresses identification and authentication requirements for organisational users?

- A. AC (Access Control)
- B. AU (Audit and Accountability)
- C. IA (Identification and Authentication)
- D. CM (Configuration Management)

Question 44 [Ch 16 — Obj 4.2]

A financial services organisation conducts a full access review across all systems and finds no violations. The external auditor notes that access reviews for the core banking system were last conducted 14 months ago, when policy requires quarterly reviews. This is a compliance finding. Why?

- A. The system itself had access violations the auditor found separately
- B. The organisation cannot demonstrate that the control operated effectively over the required period — non-completion of scheduled reviews is itself a finding
- C. The auditor disagrees with the organisation's risk assessment
- D. Quarterly reviews are not required by any compliance framework for banking systems

Question 45 [Ch 16 — Obj 4.2]

A company completes a SOC 2 Type I audit and a SOC 2 Type II audit for the same period. An enterprise customer insists on the Type II report. What additional assurance does Type II provide that Type I does not?

- A. Type II covers more Trust Services Criteria than Type I
- B. Type II confirms that controls were actually operating effectively throughout the observation period, not just that they were designed correctly at a point in time
- C. Type II is conducted by a more qualified assessor than Type I
- D. Type II includes additional testing of cryptographic controls not included in Type I

Question 46 [Ch 17 — Obj 4.3]

Which standards body governs the SAML 2.0 specification?

- A. IETF
- B. OpenID Foundation
- C. OASIS
- D. FIDO Alliance

Question 47 [Ch 17 — Obj 4.3]

An organisation wants to automatically synchronise user account creation, updates, and deletions from their HR system to a connected cloud application. Which standard is most appropriate?

- A. SAML 2.0
- B. SCIM
- C. LDAP
- D. OAuth 2.0

Question 48 [Ch 17 — Obj 4.3]

Which of the following correctly describes the relationship between OAuth 2.0 and OIDC?

- A. OAuth 2.0 is a newer version of OIDC that adds support for mobile applications
- B. OIDC is an authentication layer built on top of OAuth 2.0; OAuth 2.0 alone does not provide authentication
- C. OIDC and OAuth 2.0 are competing standards developed by different organisations for the same purpose
- D. OAuth 2.0 is used for enterprise SSO; OIDC is used for consumer identity

Question 49 [Ch 17 — Obj 4.3]

An enterprise IdP disables a user account. Connected SaaS applications continue to show the user as active for up to an hour until their access tokens expire. Which emerging standard is designed to solve this problem?

- A. SCIM — by sending a real-time deprovisioning event
- B. CAEP/SSF — by providing a signalling channel for near-instant session revocation
- C. OAuth 2.1 — by mandating shorter token lifetimes
- D. DPoP — by binding tokens to the user's device

Question 50 [Ch 17 — Obj 4.3]

Which component of the FIDO2 standard is published by the W3C?

- A. CTAP (Client to Authenticator Protocol)
- B. The FIDO2 passkey specification
- C. WebAuthn (Web Authentication)
- D. The FIDO Alliance Universal Authentication Framework

Objective 5 — Identity Operational Considerations

Question 51 [Ch 18 — Obj 5.1]

A customer contacts the support helpdesk claiming they have lost their phone and can no longer receive SMS authentication codes. The agent verifies the caller using their name, date of birth, and last four digits of their phone number, then resets the customer's MFA. Three hours later, the genuine account holder reports their account has been drained. What was the primary failure?

- A. The agent reset MFA without manager approval
- B. The verification method relied on information available from breach data, making it insufficient for a high-risk credential change
- C. The customer should not have been allowed to use SMS-based MFA
- D. The account should have been locked after three failed login attempts

Question 52 [Ch 18 — Obj 5.1]

A customer service agent at a telecommunications company regularly logs into customer accounts using the customer's own credentials to replicate the customer's experience when troubleshooting. What is the primary security risk of this practice?

- A. The agent may accidentally change the customer's password during the session
- B. The agent's actions appear in audit logs as the customer's own actions, removing attribution and creating an impersonation risk
- C. The customer's data is transmitted insecurely during the agent session
- D. The agent may inadvertently enrol in the customer's MFA programme

Question 53 [Ch 18 — Obj 5.1]

A consumer-facing healthcare portal has deployed WCAG 2.1 Level AA across its login and registration flows. A user with a visual impairment reports they cannot complete the CAPTCHA required during registration. Which of the following is the most appropriate WCAG-compliant solution?

- A. Remove the CAPTCHA entirely and replace it with a waiting period
- B. Provide an audio alternative to the visual CAPTCHA or offer an alternative verification mechanism
- C. Allow visually impaired users to skip registration and contact support directly
- D. Increase the CAPTCHA contrast ratio to WCAG AA standards

Question 54 [Ch 18 — Obj 5.1]

A super-app in Southeast Asia discovers that its account takeover rate via the support channel is unusually high. Investigation reveals that agents are updating phone numbers for callers who provide correct name, date of birth, and account number. Which additional control would most directly reduce this attack vector?

- A. Requiring agents to ask an additional knowledge-based security question before making changes
- B. Sending post-change notifications to the original phone number and email address immediately after any credential update
- C. Locking accounts for 24 hours after any phone number change request
- D. Requiring two agents to approve every credential change

Question 55 [Ch 18 — Obj 5.1]

What does a declining conversion rate on a consumer identity platform most directly indicate?

- A. The platform is experiencing a credential stuffing attack inflating login failures
- B. The identity verification process at login is too weak, allowing bot registrations that later abandon
- C. The registration or login experience has too much friction and is driving customers away before they complete sign-up
- D. The platform's MFA adoption rate is too low, causing customers to be locked out

Question 56 [Ch 19 — Obj 5.2]

A security architect is reviewing an organisation's privileged access posture and discovers that the Domain Admin group has 47 members, all of whom have permanent Domain Admin rights. Many of these users primarily use their admin accounts for email and daily work alongside their administrative tasks. What is the most significant risk this represents and what is the primary mitigation?

- A. Role creep — the mitigation is quarterly access reviews
- B. Standing privilege — the mitigation is Just-in-Time access with time-bound elevation
- C. Shared accounts — the mitigation is individual account creation with unique passwords
- D. Weak MFA — the mitigation is enforcing hardware keys for all Domain Admin accounts

Question 57 [Ch 19 — Obj 5.2]

During a forensic investigation, an organisation discovers that an attacker had persistent domain access for nine months despite their account being disabled two months into the incident. Kerberos event logs show valid authentication from accounts that had been disabled. What attack technique was most likely used to maintain this access?

- A. Pass-the-Hash, using extracted NTLM hashes from memory
- B. Credential stuffing, using breach data to bypass authentication
- C. Golden Ticket attack, using a compromised KRBTGT hash to forge Kerberos TGTs
- D. Session hijacking, reusing intercepted authentication tokens

Question 58 [Ch 19 — Obj 5.2]

What is the key property that distinguishes Zero Standing Privileges (ZSP) from standard Just-in-Time access?

- A. ZSP requires hardware security keys for all privileged account activations
- B. ZSP requires all privileged access to go through a session recording proxy
- C. ZSP means privileged accounts hold no elevated permissions at rest — every use of privilege requires an active request-approve-activate-expire cycle
- D. ZSP means privileged accounts are disabled between use and must be manually re-enabled

Question 59 [Ch 19 — Obj 5.2]

A DevOps team has hardcoded a database connection string containing DBA-level credentials in a configuration file committed to their GitHub repository. The repository is accidentally made public for 48 hours before being made private. What privileged access management control should have prevented this and what should be done immediately?

- A. Session recording — enable recording of all database sessions; rotate the hardcoded credential
- B. JIT access — implement time-bound database access; reset the credential
- C. Secrets management — credentials should be runtime-injected from a secrets vault, never stored in code; immediately rotate the exposed DBA credential
- D. Privileged access review — quarterly reviews would have detected the hardcoded credential

Question 60 [Ch 19 — Obj 5.2]

An organisation wants to prevent an attacker who has compromised a server administrator account from using that account to reach domain controllers. Which control most directly implements this?

- A. Requiring MFA for all domain controller access
- B. Implementing a Tier 0/1/2 administration model that blocks Tier 1 accounts from authenticating to Tier 0 systems
- C. Deploying session recording on all domain controllers
- D. Requiring JIT elevation before any account can access a domain controller

Question 61 [Ch 20 — Obj 5.3]

An analyst discovers that a high-severity SIEM alert for impossible travel fired three weeks ago for an account that was involved in a data exfiltration incident. The alert was triaged and marked as false positive by the on-call analyst. What is the most significant operational failure this represents?

- A. The SIEM detection rule was incorrectly configured, causing a false positive classification
- B. The analyst lacked enrichment context to distinguish the true positive from false positives, and there was no SOAR playbook to automatically contain the session pending human review
- C. The impossible-travel rule should have been disabled, as it generates too many false positives
- D. The SIEM was not collecting Entra ID sign-in logs, causing incomplete context

Question 62 [Ch 20 — Obj 5.3]

A SOC analyst notices that Event ID 4768 (Kerberos TGT requests) on a domain controller is showing a significant number of requests using RC4 encryption, despite the organisation having migrated entirely to AES256 Kerberos encryption two years ago. What attack technique does this most likely indicate?

- A. Kerberoasting — an attacker is requesting service tickets to crack offline
- B. Pass-the-Hash — an attacker is reusing NTLM hashes for authentication
- C. Golden Ticket — an attacker is forging TGTs using a compromised KRBTGT hash, which may be encrypted with an older RC4 key
- D. DCSync — an attacker is using directory replication to extract password hashes

Question 63 [Ch 20 — Obj 5.3]

An organisation's SIEM is collecting Windows Security Event logs from member servers but NOT from domain controllers. Which critical identity security events will the SIEM completely miss?

- A. Failed RDP login attempts and PowerShell execution events
- B. Kerberos TGT and service ticket events, domain-level account changes, DCSync operations, and domain group membership changes
- C. Local administrator account changes and local service installations
- D. Process creation events and network connection events

Question 64 [Ch 20 — Obj 5.3]

A new AI agent has been deployed by a development team to automate customer report generation. The agent authenticates using a service principal with Global Reader and SharePoint Read/Write permissions granted permanently. What identity governance failure does this represent, and what is the correct approach?

- A. The agent should use a different authentication method; managed identity is preferred over service principals for AI agents
- B. The agent holds standing, over-privileged permissions. It should be scoped to least privilege for its specific task, have its permissions granted JIT for each execution, have a defined owner, and be included in quarterly access reviews
- C. The agent is correctly configured — service principals with broad read permissions are the standard for AI agent authentication
- D. The agent should be blocked from deployment until it is registered in the SIEM for monitoring

Question 65 [Ch 20 — Obj 5.3]

An agentic AI system processing customer support tickets is injected with a hidden instruction embedded in a specially crafted ticket. The instruction causes the agent to call an external API and exfiltrate customer data. What type of attack is this and which monitoring control would most directly detect it?

- A. Credential stuffing — monitoring of failed authentication attempts would detect this
- B. Prompt injection — monitoring of AI agent tool call chains against defined behavioural baseline would detect the anomalous external API call
- C. Pass-the-Hash — monitoring of NTLM authentication events would detect this
- D. Golden Ticket attack — monitoring of Kerberos TGT events would detect this

Question 66 [Ch 21 — Obj 5.4]

A fintech company is building a consumer identity platform for users in the EU. Their registration form collects: name, email, password, date of birth, home address, and a profile photo for facial recognition. The service is a digital wallet that only requires authentication. Which principle is most clearly violated?

- A. Purpose limitation — the data will be used for more purposes than stated
- B. Data minimisation — significantly more data is being collected than necessary for authentication
- C. Consent — explicit consent has not been obtained for each attribute
- D. Privacy by Default — the most privacy-protective settings are not applied automatically

Question 67 [Ch 21 — Obj 5.4]

A customer submits a "right to erasure" request under GDPR. The company's identity operations team completes the deletion in the primary authentication database within 24 hours but discovers 18 days later that the customer's data still exists in a downstream CRM and three partner integration systems. What is the root cause of this failure?

- A. The right to erasure only applies to the primary identity record, not downstream systems
- B. The company lacks data lineage — a comprehensive map of where personal data flows across connected systems — making complete erasure technically impossible without manual investigation
- C. The company was compliant — downstream system deletion is the responsibility of the downstream processors
- D. The 30-day timeline had not yet expired, so no failure had occurred

Question 68 [Ch 21 — Obj 5.4]

An identity system automatically denies a user's application for a premium account based solely on an AI-generated risk score derived from their authentication history. The user is not informed of the decision logic. Under GDPR, what right has been violated?

- A. The right to data portability (Article 20)
- B. The right to erasure (Article 17)
- C. The right not to be subject to automated decision-making with significant effect, including the right to human review and explanation (Article 22)
- D. The right to restrict processing (Article 18)

Question 69 [Ch 21 — Obj 5.4]

An AI agent deployed for customer identity verification processes customer data in its context window. After each session, the context window including all customer data is logged to a debugging database without separate retention controls. What privacy principle is most directly violated?

- A. Data minimisation — the agent is collecting more data than necessary
- B. Purpose limitation — the customer data collected for identity verification is now being retained for a different purpose (system debugging) without additional legal basis
- C. Consent — the customer did not consent to the agent processing their data
- D. Privacy by Default — the logging should be off by default

Question 70 [Ch 21 — Obj 5.4]

A company operating in Singapore, EU, and Malaysia deploys a unified CIAM platform. After a breach, they discover that Malaysian users' biometric data was stored in the EU region. Under which regulations does this cross-border transfer of biometric data potentially trigger compliance obligations?

- A. GDPR only — it is an intra-EU transfer
- B. GDPR (EU transfers), Malaysia PDPA 2024 (which added biometric data as sensitive personal data in April 2025), and Singapore PDPA
- C. Only Malaysia PDPA — because the data originated in Malaysia
- D. No additional obligations — biometric data transferred between privacy-regulated jurisdictions is always permitted

Question 71 [Ch 22 — Obj 5.5]

An organisation's CISO is asked by the Board: "Who has access to our core banking systems right now?" The CISO cannot answer because identity data is spread across six different systems with no unified view. Which concept from this chapter most directly describes the root cause of this problem?

- A. Lack of PAM deployment — privileged accounts are not being managed
- B. Treating identity as a configuration rather than a system — there is no runtime observability layer providing a unified view of actual identity activity
- C. Lack of IGA governance — access certifications have not been run recently
- D. Insufficient SIEM integration — authentication logs are not being centralised

Question 72 [Ch 22 — Obj 5.5]

In the IDEAL Framework, the "Discover" pillar specifically calls out which identity category as a particular priority for continuous discovery, because visibility is the foundation for any enforcement controls?

- A. External consultant accounts
- B. Tier 0 domain administrator accounts
- C. Non-human identities and AI agents
- D. Federated partner identity accounts

Question 73 [Ch 22 — Obj 5.5]

A security team using the APEX model wants to implement the "Prioritise Continuously" pillar. They currently run quarterly vulnerability scans. Which combination of capabilities would most directly operationalise this pillar?

- A. Increasing penetration test frequency to monthly
- B. Combining a CNAPP for attack-path visibility with an identity security platform providing continuous authentication monitoring — scoring vulnerabilities by exploitability and blast radius, updated as the environment changes
- C. Deploying additional SIEM correlation rules for known vulnerability signatures
- D. Implementing daily patch deployment cycles for all systems

Question 74 [Ch 22 — Obj 5.5]

A CISO implementing the APEX "eXchange Intelligence" pillar joins a sector-specific threat intelligence sharing coalition. The first shared indicator of compromise is an unusual service account authentication pattern. How does this directly apply to identity security operations?

- A. The shared IoC allows the organisation to identify affected service accounts and apply virtual fencing or disable accounts before the attack vector is exploited in their environment
- B. The shared IoC triggers an automatic patch deployment across all systems
- C. The shared IoC updates the organisation's GDPR risk assessment
- D. The shared IoC enables the organisation to identify the attacker's country of origin

Question 75 [Ch 22 — Obj 5.5]

What is the key operational metric for measuring Zero Trust identity maturity at enterprise scale, according to the Zero Standing Privileges model?

- A. Percentage of accounts enrolled in MFA
- B. Number of privileged access reviews completed per quarter
- C. Percentage of privileged identities that hold no standing elevated permissions (ZSP coverage rate)
- D. Percentage of authentication events that are analysed by UEBA

Answer Key — Mock Exam 1

Compare your answers below. Each correct answer is shown in green. For full explanations of every question, see **Companion Document D-1** (Full 330 Q&A Answer Key) — locate the question by its original chapter and question number shown in brackets on the exam.

Q#	Ans	Chapter	Q#	Ans	Chapter
1	A	Ch 8	2	C	Ch 8
3	C	Ch 8	4	C	Ch 8
5	B	Ch 8	6	C	Ch 9
7	B	Ch 9	8	B	Ch 9
9	B	Ch 9	10	B	Ch 9
11	B	Ch 10	12	B	Ch 10
13	C	Ch 10	14	B	Ch 10
15	B	Ch 10	16	B	Ch 11
17	B	Ch 11	18	B	Ch 11
19	C	Ch 11	20	B	Ch 11
21	B	Ch 12	22	C	Ch 12
23	B	Ch 12	24	B	Ch 12
25	B	Ch 12	26	C	Ch 13
27	B	Ch 13	28	B	Ch 13
29	C	Ch 13	30	B	Ch 13
31	B	Ch 14	32	C	Ch 14
33	C	Ch 14	34	A	Ch 14
35	C	Ch 14	36	C	Ch 15
37	C	Ch 15	38	D	Ch 15
39	C	Ch 15	40	B	Ch 15
41	D	Ch 16	42	B	Ch 16
43	C	Ch 16	44	B	Ch 16
45	B	Ch 16	46	C	Ch 17

Q#	Ans	Chapter	Q#	Ans	Chapter
47	B	Ch 17	48	B	Ch 17
49	B	Ch 17	50	C	Ch 17
51	B	Ch 18	52	B	Ch 18
53	B	Ch 18	54	B	Ch 18
55	C	Ch 18	56	B	Ch 19
57	C	Ch 19	58	C	Ch 19
59	C	Ch 19	60	B	Ch 19
61	B	Ch 20	62	C	Ch 20
63	B	Ch 20	64	B	Ch 20
65	B	Ch 20	66	B	Ch 21
67	B	Ch 21	68	C	Ch 21
69	B	Ch 21	70	B	Ch 21
71	B	Ch 22	72	C	Ch 22
73	B	Ch 22	74	A	Ch 22
75	C	Ch 22			

Score calculator

Total questions: 75

Your correct answers: _____

Your score: _____ / 75 = _____%

Pass mark: 53 / 75 = 70%

Result: ■ PASS ■ FAIL

Mock Exam 2

Set your timer. Close all references. Begin.

Mock Exam 2

75 questions | 90 minutes | Pass: 53+ correct (70%)

Objective 2 — Identifiers, Identity Lifecycle & Proofing

Question 1 [Ch 8 — Obj 2.3]

A bank requires new customers to upload a copy of their passport and a live selfie, which is compared to the passport photograph using facial recognition. The bank also cross-references the customer's name and date of birth against a credit bureau database. What IAL level does this most closely describe?

- A. IAL1
- B. IAL2
- C. IAL3
- D. FAL2

Question 2 [Ch 8 — Obj 2.3]

What is the primary purpose of identity binding?

- A. To collect the minimum necessary identity attributes from an applicant
- B. To assign an appropriate Identity Assurance Level to a verified identity
- C. To securely associate a verified identity with one or more authenticators for future use
- D. To cross-reference identity attributes against authoritative data sources

Question 3 [Ch 8 — Obj 2.3]

Which of the following scenarios best illustrates a weakness in knowledge-based authentication (KBA) as an identity proofing mechanism?

- A. An applicant fails to upload a legible passport scan
- B. Fraudsters use data obtained from a breach corpus to correctly answer static personal questions
- C. A bank's facial recognition system cannot match an applicant due to poor lighting
- D. An in-person proofing appointment is unavailable due to staffing constraints

Question 4 [Ch 8 — Obj 2.3]

A CSP is evaluating whether to use the same proofing workflow for both newsletter subscribers and individuals requesting access to a national tax portal. What is the most significant problem with this approach?

- A. The same workflow cannot technically support two different services
- B. Newsletter subscribers should not have their data collected at all
- C. The risk levels of the two contexts differ significantly; one requires much stronger assurance than the other
- D. IAL levels can only be assigned to workforce identities, not customer identities

Question 5 [Ch 8 — Obj 2.3]

A fraudster submits a photograph of a real person's face in place of a live selfie during a remote identity proofing workflow, successfully passing the facial comparison step. What type of attack is this?

- A. Synthetic identity fraud
- B. Credential stuffing
- C. Presentation attack
- D. Document forgery

Objective 3 — Core Concepts of Security for Identity**Question 6** [Ch 9 — Obj 3.1]

A security team is evaluating MFA options and wants to choose the approach most resistant to real-time phishing attacks. Which option should they select?

- A. SMS one-time password
- B. TOTP authenticator app
- C. FIDO2 hardware security key
- D. Email-based one-time link

Question 7 [Ch 9 — Obj 3.1]

A user authenticates to their corporate SSO and then accesses seven internal applications during the day without re-entering credentials. Which component issues the token that allows this?

- A. Service Provider
- B. Relying Party
- C. Identity Provider
- D. Credential Service Provider

Question 8 [Ch 9 — Obj 3.1]

A bank's online platform requires only a password to log in and view account balances, but requires a password plus a push notification approval to initiate a transfer above \$10,000. What authentication pattern is this?

- A. Continuous authentication
- B. Step-up authentication
- C. Adaptive authentication
- D. Federated authentication

Question 9 [Ch 9 — Obj 3.1]

A user receives twenty push authentication requests in ten minutes on their phone. Each is an attempt by an attacker to get them to approve a fraudulent login. They eventually approve one out of frustration. What type of attack is this and what is the primary mitigation?

- A. SIM swapping; replace SMS with TOTP
- B. MFA fatigue; enable number matching in push notifications
- C. Credential stuffing; require password complexity
- D. Presentation attack; deploy liveness detection

Question 10 [Ch 9 — Obj 3.1]

A user who has been authenticated for two hours attempts to access a high-security administration panel. The system detects that the user's device has changed network (from corporate WiFi to an external IP) and requires them to re-authenticate with a second factor. What is this an example of?

- A. Step-up authentication triggered by an adaptive policy
- B. AAL1 downgrade event
- C. SAML session expiry
- D. FIDO2 re-registration

Question 11 [Ch 10 — Obj 3.2]

A hospital's access control policy states: "Users can access patient records only if their department attribute matches the patient's assigned clinical team, AND the access is from a managed device, AND the time is between 06:00 and 22:00." Which access control model does this most closely represent?

- A. Role-Based Access Control
- B. Discretionary Access Control
- C. Attribute-Based Access Control
- D. Separation of Duties

Question 12 [Ch 10 — Obj 3.2]

A DevOps engineer requests temporary admin access to a production server to apply a critical patch. Access is granted for two hours via an approval workflow and automatically revoked at expiry. What access pattern is this?

- A. Separation of Duties
- B. Role explosion mitigation
- C. Just-in-Time access
- D. Attribute-Based Access Control

Question 13 [Ch 10 — Obj 3.2]

What is the critical distinction between OAuth 2.0 and OpenID Connect (OIDC)?

- A. OAuth 2.0 is for authentication; OIDC is for authorisation
- B. OIDC is for authentication; OAuth 2.0 is for authorisation
- C. Both protocols perform authentication and authorisation simultaneously
- D. OAuth 2.0 uses XML tokens; OIDC uses JSON tokens

Question 14 [Ch 10 — Obj 3.2]

An organisation wants to implement Zero Standing Privileges for its cloud infrastructure administrators. Which approach best achieves this?

- A. Assign administrators to a permanent admin role with strong MFA
- B. Use Just-in-Time access — grant elevated permissions only on approved request with automatic expiry
- C. Require administrators to use separate accounts for privileged tasks
- D. Implement Separation of Duties across all admin accounts

Question 15 [Ch 10 — Obj 3.2]

A security review finds that an organisation has over 1,200 roles defined in its RBAC system, many of which overlap significantly, and new roles are being created for every new combination of permissions requested. What RBAC failure mode is this?

- A. Role creep
- B. Role explosion
- C. Separation of Duties violation
- D. Over-permissioning

Question 16 [Ch 11 — Obj 3.3]

An organisation wants to automatically deprovision a user's accounts across all connected SaaS applications the moment their HR record is terminated. Which protocol is specifically designed to support this?

- A. SAML
- B. OIDC
- C. SCIM
- D. FIDO2

Question 17 [Ch 11 — Obj 3.3]

A user authenticates to a corporate application at 9 AM. At 11 AM, Azure AD Identity Protection detects a suspicious login from another country, indicating the account may be compromised. The system immediately terminates the 9 AM session. What session management capability is this?

- A. Session timeout
- B. Step-up authentication
- C. Continuous access evaluation with forced revocation
- D. Session cookie expiry

Question 18 [Ch 11 — Obj 3.3]

A security team reviews authentication logs and finds 50,000 failed login attempts across 10,000 accounts over a 24-hour period. What type of attack does this pattern most likely indicate?

- A. Session hijacking
- B. SIM swapping
- C. Credential stuffing
- D. MFA fatigue

Question 19 [Ch 11 — Obj 3.3]

A user forgets their password at 2 AM and cannot access the help desk until business hours. Which access management capability would resolve this without IT involvement?

- A. Identity federation
- B. Session management with continuous access evaluation
- C. Self-service password reset with MFA verification
- D. Automated SCIM deprovisioning

Question 20 [Ch 11 — Obj 3.3]

In Zero Trust architecture, which of the following is the primary trust boundary?

- A. The corporate network perimeter
- B. The VPN tunnel
- C. The identity of the requesting entity, evaluated with device, context, and resource signals
- D. The geographic location of the user

Question 21 [Ch 12 — Obj 3.4]

What is the primary advantage of asymmetric encryption over symmetric encryption for key exchange?

- A. Asymmetric encryption is faster than symmetric encryption
- B. Asymmetric encryption uses a single shared key, simplifying key management
- C. Asymmetric encryption allows one party to publish their public key openly without enabling decryption by others
- D. Asymmetric encryption does not require a Certificate Authority

Question 22 [Ch 12 — Obj 3.4]

What three properties does a digital signature provide?

- A. Confidentiality, availability, and integrity
- B. Authenticity, integrity, and non-repudiation
- C. Encryption, hashing, and tokenisation
- D. Salting, stretching, and signing

Question 23 [Ch 12 — Obj 3.4]

A Certificate Authority discovers that one of its issued certificates has had its private key compromised. The certificate has three months remaining on its validity period. What should the CA do?

- A. Wait for the certificate to expire naturally at the end of its validity period
- B. Publish the certificate's serial number to its Certificate Revocation List (CRL) and/or OCSP responder
- C. Reissue the certificate with the same key pair and a new validity period
- D. Notify the certificate holder by email and take no further action

Question 24 [Ch 12 — Obj 3.4]

Which of the following algorithms is recommended for password hashing in a modern system?

- A. MD5
- B. SHA-1
- C. AES-256
- D. bcrypt

Question 25 [Ch 12 — Obj 3.4]

What does TLS version matter? Why should organisations ensure they use TLS 1.2 or higher?

- A. Earlier TLS versions use symmetric encryption, which is less secure than asymmetric
- B. TLS 1.0 and 1.1 have known vulnerabilities and are considered deprecated and insecure
- C. TLS 1.2+ supports SHA-256 hashing; earlier versions do not
- D. TLS 1.2 supports OCSP while earlier versions only support CRL

Question 26 [Ch 13 — Obj 3.5]

A SIEM alert fires showing 50,000 failed login attempts across 45,000 different user accounts over a 6-hour period, with each account receiving exactly one failed attempt. What type of attack does this most likely represent?

- A. Brute force attack
- B. Password spray
- C. Credential stuffing
- D. MFA fatigue attack

Question 27 [Ch 13 — Obj 3.5]

In the Cloudflare breach of November 2023, attackers gained access using credentials stolen from a third-party provider. What operational failure allowed the attack to succeed weeks after the initial breach was known?

- A. Cloudflare did not have MFA enabled on its Atlassian systems
- B. Cloudflare rotated most exposed credentials but missed two, which the attackers used
- C. Cloudflare's SIEM failed to detect the unusual login pattern
- D. The attackers bypassed FIDO2 using an AiTM proxy

Question 28 [Ch 13 — Obj 3.5]

An attacker compromises the KRBTGT account in an Active Directory domain. What does this allow them to do?

- A. Access the specific service associated with the compromised account
- B. Forge Kerberos tickets for any user in the domain, granting arbitrary access
- C. Reset passwords for all users without requiring MFA
- D. Exfiltrate all LDAP directory data

Question 29 [Ch 13 — Obj 3.5]

A web application constructs database queries using unsanitised user input, allowing an attacker to inject SQL that always evaluates to true, bypassing the authentication check entirely. What vulnerability is this?

- A. Cross-site scripting (XSS)
- B. Session hijacking
- C. SQL injection
- D. IDOR (Insecure Direct Object Reference)

Question 30 [Ch 13 — Obj 3.5]

An attacker registers an additional MFA device on a compromised account immediately after gaining initial access. What stage of the identity attack chain does this represent, and why is it dangerous?

- A. Initial access; it confirms the attacker's identity to the system
- B. Lateral movement; it allows the attacker to access other accounts
- C. Persistence; it ensures the attacker retains access even if the original password is reset
- D. Privilege escalation; it grants the attacker administrative permissions

Question 31 [Ch 14 — Obj 3.6]

A threat model review identifies that the identity system's authentication audit logs are stored in the same environment as the data they monitor, with no separate access controls. What STRIDE category does the risk of log tampering fall under?

- A. Repudiation
- B. Tampering
- C. Information Disclosure
- D. Denial of Service

Question 32 [Ch 14 — Obj 3.6]

A CIAM platform returns the error message "User not found" when a valid email address is not registered, and "Incorrect password" when the email is registered but the password is wrong. Which STRIDE threat does this create?

- A. Spoofing — the error message impersonates a legitimate response
- B. Information Disclosure — account existence is revealed to unauthenticated users
- C. Repudiation — the attacker can deny using the enumeration
- D. Denial of Service — the error responses could be used to lock accounts

Question 33 [Ch 14 — Obj 3.6]

In a Data Flow Diagram, a dashed line separates the corporate identity provider from a third-party SaaS application. What does this dashed line represent?

- A. A data flow carrying authentication assertions
- B. A trust boundary between systems with different trust levels
- C. An encrypted communication channel
- D. A firewall rule blocking direct access

Question 34 [Ch 14 — Obj 3.6]

A threat modeller applies STRIDE to a JWT token issuance endpoint and identifies that the endpoint does not require client authentication before issuing tokens. Which STRIDE categories apply?

- A. Denial of Service only
- B. Spoofing (any client can impersonate a legitimate one) and Elevation of Privilege (any client can obtain tokens with any scope)
- C. Tampering and Repudiation
- D. Information Disclosure only

Question 35 [Ch 14 — Obj 3.6]

An organisation applies STRIDE retrospectively to the Sisense breach. The primary finding is that credentials stored in the analytics platform's environment were accessible from the compromised GitLab instance because no trust boundary separated the two environments. Which STRIDE category is this?

- A. Spoofing
- B. Tampering
- C. Repudiation
- D. Information Disclosure

Objective 4 — Rules and Standards That Relate to Identity

Question 36 [Ch 15 — Obj 4.1]

An identity architect is designing a SAML federation. The Service Provider is a SaaS HR platform that needs only the user's name, email, and department. The IdP currently transmits 24 attributes including salary band, performance rating, and manager details. Which GDPR principle is most directly violated?

- A. Accuracy
- B. Storage limitation
- C. Data minimisation
- D. Purpose limitation

Question 37 [Ch 15 — Obj 4.1]

An organisation has received a right of erasure request from a former employee. The identity platform account has been deleted, but the user's personal data remains in three connected SaaS applications and the audit log archive. Has the organisation fulfilled its GDPR obligation?

- A. Yes — deleting the identity platform account satisfies the right of erasure
- B. Yes — audit logs are exempt from erasure obligations under GDPR
- C. No — erasure must extend to all connected systems unless a lawful basis for retention exists in each
- D. No — erasure must be completed within 24 hours of the request

Question 38 [Ch 15 — Obj 4.1]

PCI DSS 4.0 Requirement 8 mandates MFA for which of the following scenarios?

- A. All user access to non-cardholder systems
- B. All non-console administrative access into the cardholder data environment
- C. Only remote access from outside the corporate network
- D. Only for accounts with administrative privileges

Question 39 [Ch 15 — Obj 4.1]

Which GDPR article establishes the obligation to implement Data Protection by Design and Default?

- A. Article 5 (principles)
- B. Article 6 (lawful bases)
- C. Article 17 (right of erasure)
- D. Article 25 (data protection by design and default)

Question 40 [Ch 15 — Obj 4.1]

Under Australia's Notifiable Data Breaches scheme, how long does an organisation have to complete its assessment of whether a breach is eligible for mandatory notification?

- A. 72 hours
- B. 14 days
- C. 30 days
- D. 60 days

Question 41 [Ch 16 — Obj 4.2]

An organisation is implementing NIST 800-53 control AC-2 to manage account lifecycles across its identity systems, documenting each control's implementation status and evidence. Which compliance approach does this represent?

- A. Risk-based compliance
- B. Control-based compliance
- C. Continuous compliance
- D. Audit and certification

Question 42 [Ch 16 — Obj 4.2]

During an access review, a manager approves all 340 access items assigned to their team members in 12 minutes without reviewing individual entitlements. What compliance problem does this represent?

- A. A SoD violation
- B. Rubber-stamping — producing the appearance of compliance without the substance of review
- C. A breach of the right of access under GDPR
- D. A violation of the continuous compliance approach

Question 43 [Ch 16 — Obj 4.2]

An organisation's SoD ruleset blocks a user from being provisioned with both "create purchase order" and "approve purchase order" access simultaneously. What type of SoD control is this?

- A. Detective SoD control
- B. Compensating control
- C. Preventive SoD control
- D. Continuous SoD monitoring

Question 44 [Ch 16 — Obj 4.2]

An IGA platform is configured to automatically disable user accounts that have been inactive for 90 days, without requiring manual intervention. Which compliance approach does this most directly implement?

- A. Risk-based compliance
- B. Control-based compliance
- C. Continuous compliance with automated remediation
- D. Audit and certification

Question 45 [Ch 16 — Obj 4.2]

An identity risk assessment scores admin credentials to the SWIFT payment system as "critical" (high impact, high likelihood) and standard employee accounts as "low." Which compliance approach is being applied, and what control allocation does it imply?

- A. Control-based compliance — the same controls apply to all accounts regardless of risk
- B. Risk-based compliance — stronger controls (FIDO2, JIT, 24/7 monitoring) for SWIFT admins; standard controls for employees
- C. Continuous compliance — all accounts are monitored equally in real time
- D. Audit and certification — high-risk systems are audited more frequently

Question 46 [Ch 17 — Obj 4.3]

A developer is building a mobile banking application that needs to verify the user's identity and retrieve their profile information. Which protocol should they use?

- A. OAuth 2.0
- B. SAML 2.0
- C. LDAP
- D. OpenID Connect (OIDC)

Question 47 [Ch 17 — Obj 4.3]

What is the primary function of OAuth 2.0?

- A. Authenticating users and providing identity claims
- B. Federating enterprise SSO using XML assertions
- C. Delegating authorised access to APIs without sharing credentials
- D. Provisioning and deprovisioning user accounts

Question 48 [Ch 17 — Obj 4.3]

Under NIST SP 800-63-4 (final, July 2025), which statement about synced passkeys is correct?

- A. Synced passkeys do not qualify for any AAL level because the private key can leave the device
- B. Synced passkeys qualify as AAL3 because they use phishing-resistant cryptography
- C. Synced passkeys qualify as AAL2 under the finalised NIST SP 800-63-4 guidelines
- D. Synced passkeys are not recognised by NIST and should not be used in enterprise environments

Question 49 [Ch 17 — Obj 4.3]

A security team has deployed OAuth 2.0 for their API platform and is concerned that bearer tokens could be stolen and replayed. Which IETF extension makes tokens sender-constrained and resistant to replay?

- A. PKCE (RFC 7636)
- B. DPoP (RFC 9449)
- C. SCIM (RFC 7643)
- D. JWT Profile for Access Tokens (RFC 9068)

Question 50 [Ch 17 — Obj 4.3]

An organisation is implementing open banking in Australia and needs to comply with the Consumer Data Right (CDR) framework, which requires sender-constrained tokens, pushed authorisation requests, and mTLS. Which standard profile should they implement?

- A. SAML 2.0 Enterprise Profile
- B. OIDC Discovery
- C. FAPI (Financial-grade API)
- D. SCIM 2.0 for Open Banking

Objective 5 — Identity Operational Considerations**Question 51** [Ch 18 — Obj 5.1]

A financial services CIAM platform wants to reduce its registration abandonment rate from 68% to below 40%. Which approach is most likely to achieve this?

- A. Adding more security questions to the registration form to ensure genuine customers complete it fully
- B. Requiring identity document upload at registration to verify every customer from the start
- C. Reducing the registration form to minimum required fields and collecting additional attributes progressively over time
- D. Implementing CAPTCHA on the registration form to filter out automated registrations

Question 52 [Ch 18 — Obj 5.1]

According to the principle that account recovery must match or exceed the assurance of primary authentication, which account recovery design is most problematic?

- A. Sending a one-time recovery link to the registered email address
- B. Requiring a government ID document upload for account recovery
- C. Allowing recovery via knowledge-based questions when primary authentication requires FIDO2 passkey
- D. Requiring step-up authentication via an authenticated mobile app session before proceeding with recovery

Question 53 [Ch 18 — Obj 5.1]

Which of the following best describes "progressive profiling" in a CIAM context?

- A. Gradually increasing the security requirements for a user as their account matures
- B. Collecting customer attributes gradually over time through natural engagement rather than all at once during registration
- C. Building a detailed risk profile of each customer based on their login behaviour
- D. Progressively increasing MFA adoption by adding new factors over time

Question 54 [Ch 18 — Obj 5.1]

A customer support agent receives a call from someone who says their account has been locked and they need their email address and phone number changed. The caller provides the correct account number and date of birth. The agent makes the changes. What additional control would have best protected against this being an account takeover attack?

- A. Requiring the caller to recite the last five transactions on the account
- B. Requiring step-up authentication: sending a code to the existing phone number before changing it
- C. Escalating all email change requests to a senior agent
- D. Requiring the caller to visit a physical branch to make credential changes

Question 55 [Ch 18 — Obj 5.1]

A CIAM platform measures a login success rate of 76% on first attempt. Historically this metric has been above 94%. Which two scenarios are the most likely explanations?

- A. A recent UI change has made the login form confusing, or a credential stuffing attack is generating failed attempts
- B. The MFA adoption rate has increased, or the platform has added new geographic regions
- C. Progressive profiling has reduced the conversion rate, or account recovery requests have increased
- D. WCAG compliance changes have affected the login flow, or support tickets have increased

Question 56 [Ch 19 — Obj 5.2]

An attacker has compromised a workstation and used Mimikatz to extract an NTLM hash for a local administrator account. They are now using this hash to authenticate to other workstations on the network without knowing the account's actual password. What type of attack is this and what is the primary mitigation?

- A. Golden Ticket attack; the mitigation is resetting the KRBTGT password twice
- B. DCSync attack; the mitigation is restricting replication privileges
- C. Pass-the-Hash attack; the mitigation is deploying LAPS to ensure each workstation has a unique local administrator password
- D. Credential stuffing; the mitigation is enforcing password complexity

Question 57 [Ch 19 — Obj 5.2]

An organisation is evaluating whether to deploy traditional vault-based PAM or a vaultless PAM approach. They have 15,000 privileged accounts across a complex hybrid environment and need immediate broad coverage. They are also concerned about service account governance. Which approach better addresses their requirements and why?

- A. Traditional vault-based PAM — it provides better session recording for compliance
- B. Vaultless PAM — it provides immediate broad coverage through authentication-layer enforcement and native service account governance without requiring onboarding each account
- C. Traditional vault-based PAM — it provides better protection against Golden Ticket attacks
- D. Neither — they should implement JIT access in Entra ID PIM instead

Question 58 [Ch 19 — Obj 5.2]

An administrator on the Domain Admin team regularly uses their domain administrator account to check email, browse the internet, and perform administrative tasks from the same workstation. What tiered administration principle is being violated and what is the specific risk?

- A. Tier separation — the risk is that MFA is not enforced on the admin account
- B. Tier isolation — the risk is that Domain Admin credential hashes exist on a general-purpose Tier 2 workstation, enabling Pass-the-Hash or Golden Ticket precursor attacks if the workstation is compromised
- C. Account separation — the risk is that the administrator cannot be held accountable for specific admin actions
- D. PAW policy — the risk is that the session cannot be recorded

Question 59 [Ch 19 — Obj 5.2]

How many times must the KRBtgt password be reset to fully recover from a Golden Ticket attack and why?

- A. Once — resetting the password invalidates all existing Kerberos tickets immediately
- B. Twice — the first reset prevents new Golden Tickets; the second reset ensures all tickets signed with the first (post-breach) password are also invalidated
- C. Three times — once for each Domain Controller in the environment
- D. Once per Domain Controller — to ensure all DCs are synchronised

Question 60 [Ch 19 — Obj 5.2]

What is the primary advantage of vaultless PAM over traditional vault-based PAM specifically for service accounts?

- A. Vaultless PAM can record service account sessions more effectively
- B. Vaultless PAM enforces virtual fencing policies — restricting where and how service accounts can authenticate — without requiring credential rotation that would break dependent applications
- C. Vaultless PAM provides better compliance reporting for service accounts
- D. Vaultless PAM can rotate service account credentials automatically without any downtime

Question 61 [Ch 20 — Obj 5.3]

Which Windows Security Event ID, when observed on a domain controller, indicates that the Security event log has been cleared and should trigger immediate escalation to a P1 incident?

- A. 4625
- B. 4688
- C. 4719
- D. 1102

Question 62 [Ch 20 — Obj 5.3]

A SOAR playbook is configured to automatically disable a user account when impossible travel is detected with a high-risk Identity Protection score. The security team wants to add KRBGT password rotation as a subsequent automated step. Why would this be inappropriate?

- A. KRBGT rotation cannot be automated through Azure Logic Apps connectors
- B. KRBGT rotation is not related to Entra ID sign-in events and would not address the compromise
- C. KRBGT rotation has domain-wide impact — invalidating all active Kerberos sessions — and requires human evaluation of necessity before execution
- D. KRBGT rotation should only be performed after a forensic investigation is complete, which takes at least 48 hours

Question 63 [Ch 20 — Obj 5.3]

Which Entra ID log type contains Microsoft's machine-learning-based risk detections, including signals for leaked credentials, impossible travel, and password spray attacks?

- A. Audit logs
- B. Provisioning logs
- C. Sign-in logs
- D. Identity Protection logs

Question 64 [Ch 20 — Obj 5.3]

What is the key operational difference between an ITDR tool like Silverfort and a traditional SIEM for detecting compromised credential usage?

- A. ITDR tools monitor more log sources than SIEMs, providing broader coverage
- B. SIEMs can detect compromised credentials in real-time; ITDR tools analyse events after the fact
- C. ITDR tools enforce controls inline at the authentication layer, blocking or step-up challenging suspicious authentications before access is granted; SIEMs detect and alert after authentication has already occurred
- D. ITDR tools are only effective for cloud identity attacks; SIEMs are needed for on-premises attacks

Question 65 [Ch 20 — Obj 5.3]

A Splunk SOAR playbook detects a spike of 200 failed logins across 50 different user accounts from the same IP address within a 10-minute window, followed by 3 successful logins. What attack pattern is this and what should the playbook's first automated action be?

- A. Brute-force attack — disable the 3 accounts with successful logins
- B. Password spray attack — block the attacker IP at the perimeter, disable the 3 accounts with successful logins, and enumerate all resources accessed during those sessions
- C. Credential stuffing — send MFA challenges to all 50 accounts immediately
- D. Kerberoasting — rotate the service account passwords for all affected accounts

Question 66 [Ch 21 — Obj 5.4]

Under GDPR Article 35, which of the following identity system deployments would most clearly require a mandatory Data Protection Impact Assessment?

- A. Deploying a self-service password reset portal
- B. Implementing a biometric facial recognition system for employee building access at scale
- C. Enabling users to update their email address via their profile settings
- D. Configuring a new SAML integration with a SaaS application

Question 67 [Ch 21 — Obj 5.4]

Under the EU AI Act, which of the following practices by an identity system would be prohibited from February 2025?

- A. Using machine learning to score authentication risk based on device and location
- B. Implementing AI-based document verification for KYC onboarding
- C. Deploying real-time remote biometric identification in publicly accessible spaces without law enforcement justification
- D. Using behavioural analytics to establish normal user authentication patterns

Question 68 [Ch 21 — Obj 5.4]

Which of the following accurately describes the GDPR breach notification timeline?

- A. 30 days to notify the supervisory authority; individual notification only if requested
- B. 72 hours to notify the supervisory authority; individual notification without undue delay when the breach is likely to result in high risk to individuals
- C. 24 hours to notify both the supervisory authority and all affected individuals simultaneously
- D. Notification only required for breaches of 500 or more individuals' records

Question 69 [Ch 21 — Obj 5.4]

Biometric data is classified as "special category data" under GDPR Article 9. What practical implication does this have for identity systems implementing biometric authentication?

- A. Biometric data must be encrypted with a stronger algorithm than other personal data
- B. Biometric authentication requires a legal basis beyond standard consent — typically explicit consent or a specific national law — and automatically triggers DPIA requirements
- C. Biometric templates must be stored in a separate database from other identity attributes
- D. Users who provide biometric data have no right to erasure because biometrics are required for security

Question 70 [Ch 21 — Obj 5.4]

Which of the following most accurately describes "Privacy by Default" as a legal requirement under GDPR?

- A. The controller must apply privacy settings only after the user requests them
- B. The system must automatically apply the most privacy-protective settings so that by default personal data is not made accessible to an indefinite number of persons
- C. The system must offer privacy settings, but users may choose not to use them
- D. Privacy by Default only applies to organisations processing data of EU children

Question 71 [Ch 22 — Obj 5.5]

The IDEAL Framework defines Identity Security as a layer that should sit "atop identity infrastructure, not inside it." What practical implication does this have for deployment?

- A. The identity security platform must replace existing IAM systems
- B. The identity security platform must integrate with existing IAM without requiring changes to the underlying infrastructure, providing coverage non-disruptively
- C. The identity security platform should only monitor cloud-hosted identities
- D. Identity security can only be deployed after IGA governance is fully mature

Question 72 [Ch 22 — Obj 5.5]

The APEX Framework's first pillar — Assume Compromise — recommends deploying deception technologies including honeypots, decoy credentials, and canary service accounts. What specific threat are these designed to detect early?

- A. Phishing attacks targeting human users
- B. AI-driven lateral movement through the identity estate
- C. Insider threats misusing legitimate access
- D. Ransomware encrypting file systems

Question 73 [Ch 22 — Obj 5.5]

From the IVIP framework, what does it mean that "policy ≠ reality" in identity systems?

- A. Policies are poorly written and do not reflect actual security requirements
- B. What users are permitted to do (entitlements) does not necessarily reflect what they actually do — runtime authentication behaviour frequently diverges from configured policy
- C. Security policies are too strict and prevent legitimate business activities
- D. Identity policies are not enforced consistently across all systems

Question 74 [Ch 22 — Obj 5.5]

The "Enforce" pillar of IDEAL specifically calls out the need for an "Identity Firewall." What does this capability do during an active incident?

- A. Blocks all network traffic until the incident is resolved
- B. Proactively segments identities — blocking a compromised account from authenticating to any system — to stop the spread of the attack
- C. Encrypts all identity data stores to prevent the attacker from reading them
- D. Terminates all active sessions across the environment simultaneously

Question 75 [Ch 22 — Obj 5.5]

A break-glass account is used at 2am during a major outage. No prior alert had been set up. What operational failure does this represent?

- A. The break-glass account was not sufficiently privileged to resolve the outage
- B. Break-glass accounts should not be used during outages — they are for security incidents only
- C. The break-glass account lacked a monitoring configuration that would trigger an immediate alert on any use — a required control for all break-glass accounts
- D. The account should have been stored in the PAM vault, not accessed directly

Answer Key — Mock Exam 2

Compare your answers below. Each correct answer is shown in green. For full explanations of every question, see **Companion Document D-1** (Full 330 Q&A Answer Key) — locate the question by its original chapter and question number shown in brackets on the exam.

Q#	Ans	Chapter	Q#	Ans	Chapter
1	B	Ch 8	2	C	Ch 8
3	B	Ch 8	4	C	Ch 8
5	C	Ch 8	6	C	Ch 9
7	C	Ch 9	8	B	Ch 9
9	B	Ch 9	10	A	Ch 9
11	C	Ch 10	12	C	Ch 10
13	B	Ch 10	14	B	Ch 10
15	B	Ch 10	16	C	Ch 11
17	C	Ch 11	18	A	Ch 11
19	B	Ch 11	20	C	Ch 11
21	C	Ch 12	22	B	Ch 12
23	C	Ch 12	24	B	Ch 12
25	A	Ch 12	26	C	Ch 13
27	B	Ch 13	28	A	Ch 13
29	B	Ch 13	30	B	Ch 13
31	B	Ch 14	32	B	Ch 14
33	B	Ch 14	34	B	Ch 14
35	B	Ch 14	36	C	Ch 15
37	C	Ch 15	38	B	Ch 15
39	D	Ch 15	40	C	Ch 15
41	B	Ch 16	42	B	Ch 16
43	C	Ch 16	44	C	Ch 16
45	B	Ch 16	46	D	Ch 17

Q#	Ans	Chapter	Q#	Ans	Chapter
47	C	Ch 17	48	C	Ch 17
49	B	Ch 17	50	C	Ch 17
51	C	Ch 18	52	C	Ch 18
53	B	Ch 18	54	B	Ch 18
55	A	Ch 18	56	C	Ch 19
57	B	Ch 19	58	B	Ch 19
59	B	Ch 19	60	B	Ch 19
61	D	Ch 20	62	C	Ch 20
63	D	Ch 20	64	C	Ch 20
65	B	Ch 20	66	B	Ch 21
67	C	Ch 21	68	B	Ch 21
69	B	Ch 21	70	B	Ch 21
71	B	Ch 22	72	B	Ch 22
73	B	Ch 22	74	B	Ch 22
75	C	Ch 22			

Score calculator

Total questions: 75

Your correct answers: _____

Your score: _____ / 75 = _____%

Pass mark: 53 / 75 = 70%

Result: ■ PASS ■ FAIL